

Navigation Centrale

Documentation du Projet

- [Accueil](#) | [Documentation Centralisée](#)

Démarrage Rapide

- [Guide Installation](#) | [Guide Développement](#)

API & Intégration

- [Documentation API](#) | [API Technique](#)

Déploiement

- [Guide Déploiement](#) | [Déploiement Technique](#)

Outils Développement

- [Scripts et Makefiles](#) | [Documentation Technique](#)

Documentation Technique

- [Architecture](#) | [Base de Données](#) | [Sécurité](#) | [Performance](#)
-

Sécurité et Authentification JobbingTrack

Documentation complète de la sécurité et de l'authentification dans JobbingTrack.

Vue d'Ensemble

La sécurité est une priorité absolue dans JobbingTrack. Nous implémentons une approche **defense-in-depth** avec plusieurs couches de protection.



SÉCURITÉ

🔑 Authentification JWT	🛡️ Autorisation RBAC
🔒 Chiffrement des données	🚫 Rate Limiting
✅ Validation des entrées	📝 Audit Logging
🛡️ Protection CSRF	🔍 Monitoring de sécurité
🏠 Gestion des sessions	🆔 Input Sanitization

🔑 Authentification

JWT (JSON Web Tokens)

Structure du Token

```
{
  "header": {
    "alg": "HS256",
    "typ": "JWT"
  },
  "payload": {
    "userId": "user_123",
    "email": "user@example.com",
    "role": "USER",
    "iat": 1699123456,
    "exp": 1699209856,
    "iss": "jobbingtrack-api"
  },
  "signature": "HMACSHA256(base64Header + '.' + base64Payload, secret)"
}
```

Configuration JWT

```
// Configuration sécurisée
const jwtConfig = {
  secret: process.env.JWT_SECRET, // Clé secrète (256+ bits)
  refreshSecret: process.env.JWT_REFRESH_SECRET,
  accessTokenExpiry: '7d', // 7 jours
  refreshTokenExpiry: '30d', // 30 jours
  issuer: 'jobbingtrack-api',
  audience: 'jobbingtrack-client'
};
```

Refresh Tokens

- **Stockage sécurisé** : HTTP-only cookies
- **Rotation automatique** : Nouveau refresh token à chaque utilisation
- **Expiration indépendante** : Plus longue durée de vie
- **Invalidation** : Liste noire des tokens compromis

Autorisation (RBAC)

Rôles et Permissions

Rôle	Description	Permissions
USER	Utilisateur standard	Lecture/écriture de ses propres données
ADMIN	Administrateur	Gestion des utilisateurs, statistiques
SUPER_ADMIN	Super administrateur	Accès complet à tous les modules

Middleware d'Autorisation

```
// Vérification des permissions
const authorize = (roles) => {
  return (req, res, next) => {
    const userRole = req.user.role;
    const hasPermission = roles.includes(userRole) ||
      userRole === 'SUPER_ADMIN';

    if (!hasPermission) {
      return res.status(403).json({
        success: false,
        error: 'Accès non autorisé'
      });
    }
    next();
  };
};

// Utilisation
app.get('/admin/users', authorize(['ADMIN', 'SUPER_ADMIN']), getUsers);
```

Vérification des Ressources

- **Ownership** : L'utilisateur ne peut modifier que ses propres ressources
- **Scope** : Limitation de la visibilité selon les permissions

- **Context** : Vérification du contexte d'accès



Chiffrement des Données

Mots de Passe

```
// Hachage bcrypt avec salt
const hashedPassword = await bcrypt.hash(password, 12);

// Vérification
const isValid = await bcrypt.compare(password, hashedPassword);
```

Données Sensibles

- **Chiffrement AES-256** pour les données PII
- **Clés de chiffrement** rotation automatique
- **Stockage séparé** des clés de chiffrement



Protection contre les Attaques

Rate Limiting

Configuration Globale

```
const limiter = rateLimit({
  windowMs: 15 * 60 * 1000, // 15 minutes
  max: 100, // limite par windowMs
  message: {
    success: false,
    error: 'Trop de requêtes, réessayez plus tard'
  },
  standardHeaders: true,
  legacyHeaders: false
});
```

Rate Limiting par Endpoint

```
// Limite stricte pour l'authentification
const authLimiter = rateLimit({
```

```

windowMs: 15 * 60 * 1000,
max: 5, // 5 tentatives par 15 minutes
skipSuccessfulRequests: true
});

// Limite normale pour les autres endpoints
const apiLimiter = rateLimit({
  windowMs: 15 * 60 * 1000,
  max: 100
});

```

Protection CSRF

Configuration

```

const csrfProtection = csrf({
  cookie: {
    httpOnly: true,
    secure: process.env.NODE_ENV === 'production',
    sameSite: 'strict'
  }
});

```

Utilisation

```

// Protection CSRF pour les formulaires
app.post('/api/submit', csrfProtection, submitHandler);

```

Input Sanitization

Validation avec Joi

```

const schema = Joi.object({
  email: Joi.string().email().required(),
  password: Joi.string().min(8).pattern(/^(?=.*[a-z])(?=.*[A-Z])(?=.*\d)/),
  firstName: Joi.string().min(2).max(50).pattern(/^[a-zA-Z\s]+$/),
  phone: Joi.string().pattern(/^\+?[\d\s\-\(\)]+$/ )
});

```

Sanitisation HTML

```
const sanitizeHtml = require('sanitize-html');

const cleanHtml = sanitizeHtml(dirtyHtml, {
  allowedTags: ['p', 'br', 'strong', 'em'],
  allowedAttributes: {}
});
```



Audit et Logging

Logging de Sécurité

Événements Audités

- Connexions réussies/échouées
- Modifications de données sensibles
- Accès aux ressources administratives
- Changements de permissions
- Tentatives d'injection

Format des Logs de Sécurité

```
const securityLog = {
  timestamp: new Date().toISOString(),
  level: 'SECURITY',
  event: 'LOGIN_ATTEMPT',
  userId: req.user?.id || 'anonymous',
  ip: req.ip,
  userAgent: req.get('User-Agent'),
  success: true/false,
  details: {
    email: req.body.email,
    endpoint: req.path,
    method: req.method
  }
};
```

Monitoring de Sécurité

Alertes Automatiques

- Tentatives de connexion multiples échouées
- Accès non autorisé aux ressources sensibles

- **Modifications massives** de données
- **Activité suspecte** (pattern analysis)

Métriques de Sécurité

```
// Métriques Prometheus
const securityMetrics = {
  login_attempts_total: counter('login_attempts_total', { status: 'success|failed'
  unauthorized_access_total: counter('unauthorized_access_total'),
  suspicious_activity_total: counter('suspicious_activity_total'),
  rate_limit_hits_total: counter('rate_limit_hits_total', { endpoint: 'string' })
};
```

ID Gestion des Sessions

Cookies Sécurisés

Configuration

```
const cookieConfig = {
  httpOnly: true,           // Protège contre XSS
  secure: true,             // HTTPS uniquement en production
  sameSite: 'strict',      // Protection CSRF
  maxAge: 7 * 24 * 60 * 60 * 1000, // 7 jours
  signed: true             // Signature pour l'intégrité
};
```

Gestion des Sessions Multiples

- **Limite de sessions** par utilisateur
- **Invalidation automatique** des sessions expirées
- **Déconnexion forcée** depuis l'interface admin
- **Monitoring des sessions** actives



Monitoring de Sécurité

Détection d'Intrusion

Pattern Analysis

- **Détection de bots** (requêtes automatisées)
- **Attaques par dictionnaire** (tentatives multiples)
- **Anomalies géographiques** (connexions depuis pays suspects)
- **Activité inhabituelle** (heures/volume)

Réponse Automatique

```
// Bloquer automatiquement les IPs suspectes
const blockSuspiciousIP = async (ip, reason) => {
  await redis.setex(`blocked_ip:${ip}`, 3600, reason);
  logger.warn('IP bloquée', { ip, reason });
};
```

Security Headers

Configuration Express

```
app.use(helmet({
  contentSecurityPolicy: {
    directives: {
      defaultSrc: ['self'],
      scriptSrc: ['self', 'unsafe-inline'],
      styleSrc: ['self', 'unsafe-inline'],
      imgSrc: ['self', 'data:', 'https:'],
      connectSrc: ['self', 'https://api.linkedin.com']
    }
  },
  hsts: {
    maxAge: 31536000,
    includeSubDomains: true,
    preload: true
  }
}));
```

Protection des Données

RGPD Compliance

Droits des Utilisateurs

- **Droit d'accès** : Export complet des données
- **Droit de rectification** : Modification des données personnelles

- **Droit à l'oubli** : Suppression complète des données
- **Droit à la portabilité** : Export au format JSON

Conservation des Données

```
// Configuration de rétention
const dataRetention = {
  applications: 365 * 2,    // 2 ans
  user_profiles: 365 * 5,  // 5 ans après dernière activité
  audit_logs: 365 * 7,     // 7 ans (obligation légale)
  deleted_data: 30         // 30 jours avant suppression définitive
};
```

Chiffrement au Repos

Base de Données

- **Chiffrement des colonnes sensibles** (SSN, données bancaires)
- **Clés de chiffrement** gérées par KMS
- **Rotation automatique** des clés

Fichiers

- **Chiffrement AES-256** des fichiers uploadés
- **Intégrité** avec HMAC
- **Accès basé sur les rôles**



Outils de Sécurité

Scripts de Sécurité

```
# Audit de sécurité
./scripts/security/security-audit.sh

# Analyse des vulnérabilités
./scripts/security/vulnerability-scan.sh

# Vérification des configurations
./scripts/security/config-check.sh

# Backup des données sensibles
./scripts/security/secure-backup.sh
```

Tests de Sécurité

Tests Automatisés

- Tests d'injection SQL
- Tests XSS
- Tests CSRF
- Tests d'authentification
- Tests d'autorisation

Penetration Testing

- **OWASP ZAP** pour les scans automatisés
- Tests manuels pour les vulnérabilités métier
- Tests d'authentification multi-facteurs



Métriques de Sécurité

Tableau de Bord Sécurité

```
const securityMetrics = {
  // Authentification
  login_attempts: gauge('login_attempts_per_minute'),
  failed_logins: counter('failed_logins_total'),
  active_sessions: gauge('active_sessions_count'),

  // Accès
  unauthorized_access: counter('unauthorized_access_total'),
  resource_access: counter('resource_access_total', { resource: 'string', method:

  // Sécurité
  rate_limit_hits: counter('rate_limit_hits_total'),
  suspicious_activity: counter('suspicious_activity_total'),
  blocked_ips: gauge('blocked_ips_count')
};
```

Alertes de Sécurité

- Seuil d'échec de connexion dépassé
- Activité suspecte détectée
- Tentatives d'accès non autorisé
- Modifications de données sensibles

Gestion des Incidents

Procédure d'Incident

1. **Détection** : Monitoring automatique
2. **Évaluation** : Analyse de la sévérité
3. **Containment** : Isolation de l'incident
4. **Eradication** : Suppression de la menace
5. **Recovery** : Restauration des services
6. **Lessons Learned** : Amélioration des processus

Communication

- **Notification automatique** des équipes concernées
- **Communication client** si impact utilisateur
- **Rapport d'incident** détaillé

Sécurité Future

Améliorations Planifiées

- **Authentification multi-facteurs (MFA)**
- **Chiffrement homomorphe** pour les calculs sur données chiffrées
- **Zero-trust architecture** complète
- **IA pour la détection d'anomalies**

Conformité

- **SOC 2 Type II** certification
- **ISO 27001** implémentation
- **RGPD** compliance complète
- **HIPAA** pour les données de santé (si applicable)

 **Sécurité JobbingTrack** - Protection maximale de vos données de candidatures professionnelles.

Navigation

-  [Index](#)
-  [Accueil](#)